

- 1 Incident Response Policy
 - 1.1 Table of Contents
 - 1.2 Executive Summary
 - 1.3 Policy Overview
 - 1.3.1 1.1 Purpose
 - 1.3.2 1.2 Scope
 - 1.3.3 1.3 Governing Principles
 - 1.4 Incident Definition & Classification
 - 1.4.1 2.1 What Constitutes an Incident
 - 1.4.2 2.2 Severity Classification
 - 1.5 Incident Response Team
 - 1.5.1 3.1 Team Composition
 - 1.5.2 3.2 Team Contact Information
 - 1.5.3 3.3 On-Call Procedures
 - 1.6 Response Procedures
 - 1.6.1 4.1 Incident Response Phases
 - 1.6.2 4.2 Phase 1: Detection & Reporting
 - 1.6.3 4.3 Phase 2: Initial Assessment (Target: 15 minutes)
 - 1.6.4 4.4 Phase 3: Containment (Target: 1-4 hours)
 - 1.6.5 4.5 Phase 4: Investigation & Analysis (Target: 1+ days)
 - 1.6.6 4.6 Phase 5: Eradication & Remediation (Target: Ongoing)
 - 1.6.7 4.7 Phase 6: Recovery & Verification (Target: Ongoing)
 - 1.6.8 4.8 Phase 7: Post-Incident Review (Target: 1 week)
 - 1.7 Communication & Notification
 - 1.7.1 5.1 Internal Communication
 - 1.7.2 5.2 External Communication
 - 1.7.3 5.3 User Notification (If Applicable)
 - 1.7.4 5.4 Third-Party Notification
 - 1.8 Roles & Responsibilities
 - 1.8.1 6.1 Incident Commander
 - 1.8.2 6.2 Security Lead
 - 1.8.3 6.3 Technical Lead
 - 1.8.4 6.4 Communications Lead
 - 1.8.5 6.5 Management Representative
 - 1.9 Escalation & Decision Making
 - 1.9.1 7.1 Escalation Path
 - 1.9.2 7.2 Decision Matrix
 - 1.10 Containment Strategies
 - 1.10.1 8.1 Technical Containment
 - 1.10.2 8.2 Process Containment
 - 1.10.3 8.3 Communication Containment
 - 1.11 Recovery & Remediation
 - 1.11.1 9.1 Recovery Procedures
 - 1.11.2 9.2 Patch & Update Process
 - 1.12 Post-Incident Activities
 - 1.12.1 10.1 Documentation
 - 1.12.2 10.2 Post-Incident Review Meeting
 - 1.12.3 10.3 Continuous Improvement
 - 1.13 Compliance & Legal
 - 1.13.1 11.1 Legal Obligations

- 1.13.2 11.2 Forensic Evidence Handling
- 1.13.3 11.3 External Coordination
- 1.14 Training & Drills
 - 1.14.1 12.1 Initial Training
 - 1.14.2 12.2 Drills & Simulations
 - 1.14.3 12.3 Knowledge Base
- 1.15 Tools & Resources
 - 1.15.1 13.1 Tools Required
 - 1.15.2 13.2 Documentation Templates
 - 1.15.3 13.3 Emergency Contacts
- 1.16 Appendices
 - 1.16.1 A. Incident Severity Examples
 - 1.16.2 B. Response Time Targets
 - 1.16.3 C. Incident Checklist
 - 1.16.4 D. Communication Templates
- 1.17 Policy Review & Updates
 - 1.17.1 E.1 Review Schedule
 - 1.17.2 E.2 Updates
- 1.18 Document Information
- 1.19 Approval & Sign-Off

1 Incident Response Policy

Fuzzy Monster - QuizTimer4Zoom Application Effective Date: 2025-10-28 **Last Updated:** 2025-10-28 **Classification:** Internal - Sensitive **Company:** Fuzzy Monster **Domain:** fuzzy.monster **Contact:** Latz (info@fuzzy.monster)

1.1 Table of Contents

1. [Executive Summary](#)
 2. [Policy Overview](#)
 3. [Incident Definition & Classification](#)
 4. [Incident Response Team](#)
 5. [Response Procedures](#)
 6. [Communication & Notification](#)
 7. [Roles & Responsibilities](#)
 8. [Escalation & Decision Making](#)
 9. [Containment Strategies](#)
 10. [Recovery & Remediation](#)
 11. [Post-Incident Activities](#)
 12. [Compliance & Legal](#)
 13. [Training & Drills](#)
 14. [Tools & Resources](#)
 15. [Appendices](#)
-

1.2 Executive Summary

This Incident Response Policy establishes Fuzzy Monster's procedures for identifying, responding to, and recovering from security incidents affecting QuizTimer4Zoom. The policy ensures:

- **Rapid Detection** - Quick identification of security events
- **Effective Response** - Coordinated, decisive action
- **Minimal Impact** - Limiting damage and recovery time
- **Compliance** - Meeting legal and regulatory requirements
- **Continuous Improvement** - Learning from incidents

Policy Scope: All incidents affecting QuizTimer4Zoom, including but not limited to: - Unauthorized access attempts - Data breaches - Service disruptions - Malware infections - Configuration errors - Third-party compromises

1.3 Policy Overview

1.3.1 1.1 Purpose

To establish a standardized, documented process for managing security incidents that: 1. Minimizes the impact of incidents 2. Ensures rapid detection and response 3. Meets legal and regulatory obligations 4. Preserves evidence for investigation 5. Enables lessons learned and prevention

1.3.2 1.2 Scope

In Scope: - Security incidents affecting QuizTimer4Zoom - Data breaches or potential breaches - Unauthorized system access - Service unavailability due to security issues - Third-party incidents affecting our systems - Security vulnerabilities in production

Out of Scope: - Non-security operational issues - User support requests - Feature requests - Performance issues (non-security) - Minor bugs without security impact

1.3.3 1.3 Governing Principles

1. Transparency - Honest communication about incidents - Timely disclosure to affected parties - Admit mistakes and learn from them

2. User-First Approach - Prioritize protecting user data - Notify users of breaches affecting them - Provide guidance on protective measures

3. Cooperation - Work with law enforcement if needed - Collaborate with Zoom for marketplace incidents - Share threat intelligence when appropriate

4. Accountability - Clear ownership and decision-making - Document all actions taken - Review and improve processes

5. Legal Compliance - Meet GDPR breach notification requirements (72 hours) - Comply with CCPA obligations - Follow local data protection laws - Preserve evidence for legal action

1.4 Incident Definition & Classification

1.4.1 2.1 What Constitutes an Incident

An **incident** is any event that: - Breaches confidentiality (unauthorized data access) - Compromises integrity (unauthorized data modification) - Disrupts availability (denial of service) - Violates security policy or law - Has potential to do any of the above

Examples: - Successful unauthorized login - Attempted hacking/brute force - Malware or ransomware infection - Data breach or data theft - Accidental data exposure - Service unavailability for 15+ minutes - Security misconfiguration - Phishing attack on team member - Third-party service compromise - Insider threat or policy violation

1.4.2 2.2 Severity Classification

1.4.2.1 Critical (CVSS 9.0-10.0 or equivalent impact)

- **Definition:** Immediate threat to system availability, data confidentiality, or integrity
- **Examples:**
 - Active data breach in progress
 - Complete service unavailability
 - Attacker with system access
 - Encryption/ransomware attack
 - Large-scale data exfiltration
- **Response Time:** Immediate (within 15 minutes)
- **Notification:** 1 hour to leadership, 24 hours to users

1.4.2.2 High (CVSS 7.0-8.9)

- **Definition:** Significant security impact with potential for escalation
- **Examples:**
 - Attempted unauthorized access (unsuccessful)
 - Vulnerability allowing remote code execution
 - Partial data exposure (<100 records)
 - Service degradation (>30% impact)
 - Privilege escalation opportunity
- **Response Time:** Within 1 hour
- **Notification:** 4 hours to leadership, 72 hours to users (GDPR)

1.4.2.3 Medium (CVSS 4.0-6.9)

- **Definition:** Moderate security issue that requires attention
- **Examples:**
 - Vulnerability in non-critical system
 - Failed attack attempt

- Minor data exposure (<10 records)
- Configuration error
- Low-impact service disruption
- **Response Time:** Within 4 hours
- **Notification:** 1 business day to leadership, 30 days to users

1.4.2.4 Low (CVSS 0.1-3.9)

- **Definition:** Minor security issue with low impact
 - **Examples:**
 - Information disclosure (non-sensitive)
 - Failed login attempts (normal volume)
 - Deprecated protocol use
 - Warning in security scan
 - **Response Time:** Within 1 business day
 - **Notification:** Weekly summary to leadership, no user notification
-

1.5 Incident Response Team

1.5.1 3.1 Team Composition

Primary Team: - **Incident Commander** - Overall coordination and decision-making - **Security Lead** - Security assessment and forensics - **Technical Lead** - System access, investigation, remediation - **Communications Lead** - Internal and external messaging - **Management Representative** - Escalation and resource approval

Extended Team (as needed): - Legal Counsel - Legal obligations, disclosure requirements - Data Protection Officer - GDPR compliance, user notifications - Marketing/PR - Public communications - Third-party Vendors - If their systems are involved - Law Enforcement - If required/authorized

1.5.2 3.2 Team Contact Information

Fuzzy Monster Incident Response Contacts:

Role	Name	Email	Phone
Incident Commander	Latz	security@fuzzy.monster	[Your number]
Security Lead	Latz	security@fuzzy.monster	[Your number]
Technical Lead	Latz	security@fuzzy.monster	[Your number]
Communications Lead	Latz	info@fuzzy.monster	[Your number]
Management	Latz	info@fuzzy.monster	[Your number]

External Contacts:

Entity	Contact	Use Case
Zoom Security	[Zoom security contact]	Marketplace incident escalation
Legal Counsel	[Your lawyer]	Legal advice, disclosure
DPA	[Data Protection Authority]	GDPR consultation
Law Enforcement	[Local police/FBI]	Crime reporting

1.5.3 3.3 On-Call Procedures

Availability: - 24/7 on-call rotation for critical incidents - Business hours (9am-5pm) for non-critical - After-hours contact: security@fuzzy.monster

Escalation: - Level 1: Try primary contact (Latz) - Level 2: Try secondary contact - Level 3: Emergency escalation to management

1.6 Response Procedures

1.6.1 4.1 Incident Response Phases

Phase 1: Detection & Reporting

↓

Phase 2: Initial Assessment (15 mins)

↓

Phase 3: Containment (1-4 hours)

↓

Phase 4: Investigation & Analysis (1+ days)

↓

Phase 5: Eradication & Remediation (ongoing)

↓

Phase 6: Recovery & Verification (ongoing)

↓

Phase 7: Post-Incident Review (1 week)

1.6.2 4.2 Phase 1: Detection & Reporting

How Incidents are Detected: 1. Automated monitoring alerts 2. User reports 3. Security scanning results 4. Manual discovery by team 5. Third-party notification 6. Threat intelligence

Reporting Process:

Anyone who suspects an incident should:

1. **Immediately Report** to Incident Commander
 - Email: security@fuzzy.monster
 - Subject: "SECURITY INCIDENT REPORT"
 - Include: What, when, where, how you discovered it

2. Do NOT:

- Delete or modify evidence
- Tell other users (yet)
- Share incident details on public channels
- Continue normal operations if possible

3. Preserve:

- System logs
- Network traffic logs
- System state (screenshots)
- Timeline of events
- Any suspicious files

Example Report:

Subject: SECURITY INCIDENT REPORT

Severity: CRITICAL

Detected: 2025-10-28 14:30 UTC

Discoverer: [Name]

Description:

Multiple failed login attempts to admin account detected in last 10 minutes. Possible brute force attack.

Evidence:

- Failed logins from IP: 192.0.2.1
- Attempt count: 47 in 10 minutes
- Accounts targeted: admin, root
- Detection method: Alert from monitoring system

Contact: [Your email/phone]

Response: Incident Commander confirms receipt within 15 minutes

1.6.3 4.3 Phase 2: Initial Assessment (Target: 15 minutes)**Incident Commander Actions:****1. Activate Response Team**

- Notify all team members
- Establish communication channel
- Brief team on initial findings

2. Confirm the Incident

- Verify it's a real incident, not false positive
- Assess initial severity
- Determine if ongoing attack

3. Quick Facts Gathering

- What system is affected?
- When did it start?
- Who/what is affected?
- Immediate threat?

4. Initial Decision

- Activate full response? (YES for critical)

- Notify leadership? (YES)
- Begin containment? (MAYBE)

Assessment Template:

Incident ID: INC-2025-001
Severity: CRITICAL
Scope: Authentication system
Affected: Admin account
Timeline: 2025-10-28 14:30 UTC - ongoing
Status: Active investigation
Next: Containment (15 minutes)

1.6.4 4.4 Phase 3: Containment (Target: 1-4 hours)

Goal: Stop the attack, prevent spread, preserve evidence

Short-term Containment (First 30 minutes):

For **Critical** incidents: 1. Isolate affected systems (if safe) 2. Disconnect from network (if necessary) 3. Block attacker IP/account 4. Stop data exfiltration 5. Preserve system state (snapshot) 6. Maintain evidence

For **High** incidents: 1. Monitor affected systems closely 2. Prepare isolation procedures 3. Ready rollback procedures 4. Brief stakeholders 5. Plan containment approach

For **Medium/Low** incidents: 1. Continue monitoring 2. Prevent spread 3. Gather information 4. Plan response

Medium-term Containment (1-4 hours):

1. System Hardening:

- Reset compromised credentials
- Apply emergency patches
- Update firewall rules
- Review access logs

2. Network Segmentation:

- Isolate affected systems
- Block suspicious IPs
- Restrict access patterns
- Monitor for lateral movement

3. Evidence Preservation:

- Capture memory dumps
- Back up logs
- Document system state
- Create forensic images

4. Communication:

- Brief leadership (30 min mark)
- Prepare stakeholder updates
- Plan user notifications (if needed)
- Contact legal if breach

1.6.5 4.5 Phase 4: Investigation & Analysis (Target: 1+ days)

Goal: Understand what happened and how

Investigation Steps:

1. **Timeline Reconstruction**
 - When did attack start?
 - What happened in sequence?
 - When was it detected?
 - Are there earlier precursor events?
2. **Attack Vector Analysis**
 - How did attacker get in?
 - What vulnerabilities used?
 - What tools/techniques used?
 - How did they move laterally?
3. **Scope Determination**
 - What systems accessed?
 - What data exposed?
 - How many users affected?
 - What was exfiltrated?
4. **Root Cause Analysis**
 - Why did this happen?
 - What was the underlying cause?
 - Could it have been prevented?
 - What failed in detection?
5. **Attacker Attribution** (if applicable)
 - Internal or external?
 - Nation-state, criminal, activist?
 - Motivation?
 - Skill level?

Investigation Tools: - System logs analysis - Network traffic analysis - File system forensics - Memory forensics - Threat intelligence feeds - Historical baselines

1.6.6 4.6 Phase 5: Eradication & Remediation (Target: Ongoing)

Goal: Remove attacker access, fix vulnerabilities, prevent recurrence

Eradication Actions:

1. **Remove Attacker Access**
 - Reset all passwords
 - Revoke compromised tokens
 - Remove backdoors
 - Close attack vectors
 - Verify attacker is gone
2. **Fix Root Causes**
 - Patch vulnerabilities
 - Update configurations
 - Improve monitoring
 - Enhance access controls
3. **Prevent Recurrence**
 - Deploy additional controls

- Update detection rules
- Implement new safeguards
- Document lessons learned

Remediation Plan:

Priority 1 (Immediate):

- [] Reset compromised passwords
- [] Block attacker IP/access
- [] Isolate affected systems
- [] Apply emergency patch

Priority 2 (24 hours):

- [] Update firewall rules
- [] Deploy detection signatures
- [] Implement additional monitoring
- [] Strengthen access controls

Priority 3 (1 week):

- [] Complete architecture review
- [] Implement long-term fixes
- [] Update documentation
- [] Conduct full security assessment

1.6.7 4.7 Phase 6: Recovery & Verification (Target: Ongoing)

Goal: Restore systems to normal, verify incident is resolved

Recovery Steps:

1. System Restoration

- Restore from clean backups
- Rebuild compromised systems
- Verify integrity
- Test functionality

2. Verification

- Confirm attacker cannot re-enter
- Verify all patches applied
- Check all controls working
- Run security scans

3. Monitoring

- Enhanced monitoring for 30 days
- Alert on suspicious activity
- Monitor for compromise indicators
- Watch for attacker return

4. Communication

- Notify users systems are restored
- Provide guidance on security measures
- Publish incident timeline (if public)
- Thank responders

Recovery Checklist: - [] All systems restored - [] All tests passing - [] All patches applied - [] Monitoring enhanced - [] Users notified - [] External parties informed - [] Evidence archived - [] Post-incident scheduled

1.6.8 4.8 Phase 7: Post-Incident Review (Target: 1 week)

Goal: Learn from incident, prevent recurrence

Review Meeting: Within 1 week of incident resolution

Attendees: - Incident Commander - All response team members - Management - Relevant stakeholders

Review Agenda:

1. **What Happened?**
 - Timeline of events
 - What was attacked
 - Attack vector used
 - Impact assessment
2. **What Did We Do Right?**
 - Quick detection
 - Good response
 - Effective containment
 - Clear communication
3. **What Could We Improve?**
 - Detection could be faster?
 - Response could be better?
 - Controls that failed?
 - Monitoring gaps?
4. **What Will We Change?**
 - Process improvements
 - Technical controls
 - Monitoring enhancements
 - Training needed
5. **Action Items**
 - Who? What? When?
 - Track progress
 - Verify completion

Post-Incident Report:

INCIDENT REPORT INC-2025-001

Date: 2025-10-28

Type: Brute Force Attack

Severity: CRITICAL

Duration: 30 minutes (detection to containment)

Users Affected: 0 (prevented by rate limiting)

Data Exposed: 0

Cost: Staff time for response

Timeline: [Detailed timeline]

Impact: [What happened]

Root Cause: [Why it happened]

Response: [What we did]

Lessons Learned:

1. [Lesson 1]
2. [Lesson 2]
3. [Lesson 3]

Improvements:

1. [Action item]
2. [Action item]
3. [Action item]

Prevention: [How to prevent next time]

1.7 Communication & Notification

1.7.1 5.1 Internal Communication

During Incident:

Phase	Who	What	When	How
Detection	Response Team	Incident alert	Immediate	Slack/Email
Assessment	Team + Mgmt	Situation brief	15 min	Call/Chat
Containment	Team	Status update	30 min	Call/Chat
Investigation	Team	Progress update	Hourly	Slack/Email
Resolution	Mgmt	All-clear message	Upon completion	Email

Communication Channels: - Critical/Urgent: Phone call + email - Important: Slack + email - Updates: Slack only - Post-incident: Email report

Message Template (Internal):

INCIDENT UPDATE - [INC-2025-001]

Status: ACTIVE / CONTAINED / RESOLVED

Severity: CRITICAL

Current Time: [time]

Situation:

[Brief description of what's happening]

Impact:

[What systems/users affected]

Actions Taken:

[What we're doing to fix it]

Next Steps:

[What happens next]

ETA to Resolution: [Estimate]

Questions: Contact [Incident Commander]

1.7.2 5.2 External Communication

Decision Matrix:

Incident Type	Notify Zoom?	Notify Users?	Public Statement?
App unavailability >1 hour	YES (1 hour)	YES (1 hour)	Maybe
Data breach	YES (24 hrs)	YES (72 hrs)	Maybe
Security vulnerability	YES (24 hrs)	NO	Maybe
Failed attack attempt	NO	NO	NO
User account compromised	NO	YES (1 hour)	NO

1.7.3 5.3 User Notification (If Applicable)

For Data Breach (GDPR Required):

Timeline: Within 72 hours of discovery

Content Must Include: - What happened (describe incident) - When it happened - What data was affected - Who was affected - What users should do - Contact for questions - Our apology and commitment

Example Notification:

Subject: Important Security Alert - QuizTimer4Zoom

Dear User,

We are writing to inform you of a security incident that may have affected your account.

WHAT HAPPENED:

On [date] at [time], unauthorized access to our authentication system was detected and contained within 30 minutes.

WHAT DATA WAS AFFECTED:

- Your email address
- Your Zoom user ID
- (NOT: passwords, payment data, or content)

WHO WAS AFFECTED:

Approximately [X] users had their data in the affected timeframe.

WHAT WE'RE DOING:

- Incident has been contained
- Root cause has been identified and fixed
- Enhanced monitoring is now in place
- Systems have been restored

WHAT YOU SHOULD DO:

- ☐ Review your account for suspicious activity
- ☐ Change your Zoom password
- ☐ Enable multi-factor authentication if available
- ☐ Contact us if you notice anything unusual

We sincerely apologize for this incident. Your security and privacy are our highest priority.

Questions? Contact us at: info@fuzzy.monster

Regards,

Fuzzy Monster Security Team

1.7.4 5.4 Third-Party Notification

Zoom Marketplace: - Notify within 24 hours if incident affects marketplace - Provide incident summary and timeline - Explain remediation measures - Update status regularly

Law Enforcement (If Criminal): - Contact local police/FBI - Provide forensic evidence - Cooperate with investigation - Document all communications

Regulatory Bodies: - GDPR: Notify DPA if >10 users or significant breach - CCPA: Notify California Attorney General (if applicable) - Local laws: Comply with regional requirements

1.8 Roles & Responsibilities

1.8.1 6.1 Incident Commander

Authority: Makes all operational decisions during incident

Responsibilities: - Activate response team - Assess severity - Make containment decisions - Authorize remediation - Communicate with leadership - Approve external notifications - Schedule post-incident review - Sign off on incident closure

Decision-Making: - Prioritizes user safety - Balances speed vs. thoroughness - Escalates when needed - Documents decisions - Takes responsibility

1.8.2 6.2 Security Lead

Responsibilities: - Assess security impact - Conduct forensic investigation - Determine attacker identity/motivation - Recommend security improvements - Review evidence - Brief team on findings - Document technical details

Skills Needed: - Security expertise - Forensic analysis - Log analysis - System security knowledge - Threat intelligence

1.8.3 6.3 Technical Lead

Responsibilities: - Provide system access for investigation - Execute containment procedures - Implement patches/fixes - Restore systems - Verify remediation - Manage backups - Coordinate with vendors

Skills Needed: - System administration - Network knowledge - Troubleshooting - Emergency procedures - Backup/recovery

1.8.4 6.4 Communications Lead

Responsibilities: - Prepare notifications - Coordinate messaging - Draft external communications - Track who has been notified - Address media inquiries - Maintain communication log - Document all communications

Skills Needed: - Clear writing - Crisis communication - Sensitivity to users - PR experience - Crisis management

1.8.5 6.5 Management Representative

Responsibilities: - Authorize resource expenditure - Make business decisions - Coordinate with executives - Approve external notifications - Track business impact - Manage liability - Update board/stakeholders

Authority: Can override technical decisions for business reasons

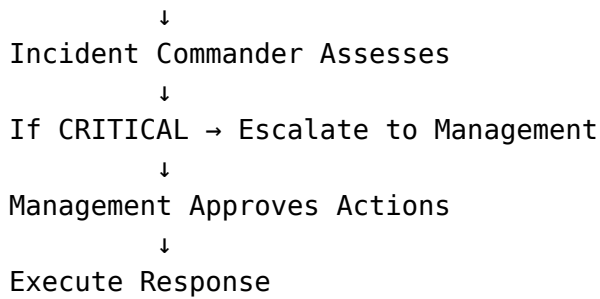
1.9 Escalation & Decision Making

1.9.1 7.1 Escalation Path

Team Member Detects Incident

↓

Reports to Incident Commander



1.9.2 7.2 Decision Matrix

Containment Decision:

Question	YES →	NO →
Is attack ongoing?	Contain immediately	Monitor only
Could it spread?	Isolate affected systems	Continue response
Is data at risk?	Stop exfiltration	Continue investigation
Will delay cause more damage?	Act immediately	Wait for more info

Notification Decision:

Criteria	Notify	Don't Notify
Data breach?	YES	NO
Personal data exposed?	YES	NO
>10 users affected?	YES	NO
Failed attack attempt?	NO	YES
Temporary service outage?	MAYBE	-

Public Disclosure Decision:

Factor	Disclose	Don't Disclose
Legal requirement?	YES	NO
Regulatory requirement?	YES	NO
Significant impact?	YES	NO
Attacked before?	YES	NO
Public trust at risk?	YES	NO

1.10 Containment Strategies

1.10.1 8.1 Technical Containment

Immediate Actions (First 30 minutes):

- # Block attacker
 1. Identify attacker IP/account
 2. Block at firewall
 3. Revoke API tokens
 4. Reset passwords
 5. Disable accounts

- # Stop bleeding
 1. Stop data exfiltration (kill process)
 2. Disconnect compromised systems
 3. Prevent lateral movement
 4. Close attack vector

- # Preserve evidence
 1. Capture system state
 2. Back up logs
 3. Create forensic image
 4. Take screenshots

System Isolation Procedure:

1. Decide: Can system stay online safely?
 - If YES: Monitor closely but leave online
 - If NO: Isolate immediately

2. If isolating:
 - Note current state (screenshot/memory dump)
 - Disconnect from network
 - Preserve power state if possible
 - Don't shut down (may lose evidence)

3. After isolation:
 - Analyze in isolated environment
 - Look for persistence mechanisms
 - Determine extent of compromise
 - Plan recovery

1.10.2 8.2 Process Containment

Service Degradation: - Run in limited mode - Reduce access scope - Increase monitoring - Prepare to shutdown if needed

Rate Limiting: - Reduce request limits - Enable CAPTCHA if applicable - Block suspicious patterns - Slow attacker progress

Access Restriction: - Require VPN for access - Increase authentication factors - Whitelist known IPs - Temporary access policies

1.10.3 8.3 Communication Containment

Information Control: - Limit who knows details - Use secure channels only - Avoid public forums - No details in regular emails - Use encrypted messaging

Message Control: - Single point of communication (communications lead) - Pre-approved messaging - Consistent story - No speculation - Verified facts only

1.11 Recovery & Remediation

1.11.1 9.1 Recovery Procedures

System Recovery:

1. Verify attacker is gone
 - Check access logs
 - Look for backdoors
 - Verify patches applied
 - Confirm credentials reset
2. Restore from clean backup
 - Find last known good backup
 - Verify backup integrity
 - Restore to isolated environment
 - Test thoroughly
3. Restore to production
 - Controlled rollout
 - Monitor closely
 - Verify functionality
 - Test security controls
4. Enhanced monitoring (30 days)
 - Watch for attacker return
 - Look for compromise indicators
 - Alert on suspicious activity
 - Daily review of logs

Data Recovery:

1. Verify data integrity
 - Check file checksums
 - Verify data validity
 - Look for corruption
 - Test functionality
2. Notify affected users
 - Explain what happened
 - Confirm data security

- Provide timeline
 - Offer support
3. Log and document
 - What data was affected
 - Recovery procedures used
 - Verification performed
 - Users notified

1.11.2 9.2 Patch & Update Process

Emergency Patches:

1. Identify vulnerability
2. Develop fix
3. Test in isolated environment
4. Deploy to production
5. Verify fix
6. Monitor for issues
7. Document patch
8. Communicate to users

Timeline: - Critical: Deploy within 24 hours - High: Deploy within 1 week - Medium: Deploy in next release - Low: Deploy in regular update cycle

1.12 Post-Incident Activities

1.12.1 10.1 Documentation

Required Documents:

1. **Incident Report**
 - o Timeline of events
 - o Actions taken
 - o Results/outcome
 - o Impact assessment
 - o Root cause
 - o Lessons learned
2. **Forensic Report** (for serious incidents)
 - o Technical findings
 - o Evidence collected
 - o Attacker methods
 - o System state at time of compromise
 - o Recovery steps
3. **Communications Log**
 - o Who was notified
 - o When notified
 - o What was said
 - o Responses received
4. **Action Item List**

- What needs to be fixed
- Who is responsible
- By when
- Verification method

1.12.2 10.2 Post-Incident Review Meeting

Schedule: Within 1 week of incident resolution

Attendees: - Incident Commander - Response team members - Management - Relevant stakeholders

Duration: 1-2 hours

Agenda:

1. Welcome & ground rules (5 min)
 - No blame, focus on learning
 - Everyone's input valued
 - Constructive discussion
2. Timeline review (15 min)
 - What happened when
 - Detection to resolution
 - Key decision points
3. Response assessment (15 min)
 - What went well?
 - What could be better?
 - Any surprises?
 - Did procedures work?
4. Lessons learned (15 min)
 - Why did this happen?
 - How do we prevent?
 - What systemic issues?
 - What's within our control?
5. Action items (10 min)
 - What will we change?
 - Who's responsible?
 - By when?
 - How will we verify?
6. Next steps (5 min)
 - Document findings
 - Track action items
 - Follow-up meeting
 - Thank responders

1.12.3 10.3 Continuous Improvement

After Each Incident: - [] Complete incident report - [] Hold post-incident review meeting - [] Identify root causes - [] Create action items - [] Assign owners - [] Set deadlines

For Next Incident: - [] Implement improvements - [] Update procedures - [] Train team - [] Test new controls - [] Document changes

Metrics to Track: - Detection time - Response time - Containment time - Recovery time - Cost/impact - User notifications - Compliance status

1.13 Compliance & Legal

1.13.1 11.1 Legal Obligations

GDPR (European Union): - Notify DPA if breach impacts >10 users or is serious - Notify affected users within 72 hours - Document incident and response - Maintain records for 3 years

CCPA (California): - Notify California Attorney General (if breach >500 CA residents) - Notify affected individuals without unreasonable delay - Maintain incident records - Determine if information was “compromised”

Other Laws: - Check local data protection regulations - Financial Institutions: May have stricter requirements - Healthcare: HIPAA requirements may apply - Payment Cards: PCI-DSS if applicable

Documentation: - Keep all incident records - Maintain confidentiality (attorney-client privilege if possible) - Archive forensic evidence - Preserve communication records - Track legal holds

1.13.2 11.2 Forensic Evidence Handling

Preservation: - Isolate affected systems immediately - Don't modify anything (read-only access) - Create forensic image of drive - Preserve RAM (memory dump) - Back up all logs - Chain of custody documentation

Investigation: - Use write-blockers for disk access - Document all findings - Keep evidence in secure location - Limit access to evidence - Maintain investigation log

Retention: - Keep evidence minimum 1 year - Longer if legal hold in place - Secure storage (encrypted, access-controlled) - Documented retention procedures

Destruction: - Only after legal approval - Secure deletion (not just delete) - Document destruction date/method - Keep destruction certificate

1.13.3 11.3 External Coordination

Law Enforcement: - Contact if incident is criminal - Preserve evidence for their investigation - Cooperate fully with investigation - Don't destroy potential evidence - Report status of investigation

Zoom: - Notify of incidents affecting marketplace - Provide incident summary - Explain business impact - Discuss remediation - Update on resolution

Regulatory Bodies: - Notify if legally required - Provide requested information - Cooperate with investigation - Document all communications

1.14 Training & Drills

1.14.1 12.1 Initial Training

All Staff: - Incident response procedures - How to report incidents - What not to do during incident - Role of incident response team - Communication procedures

Response Team: - Detailed incident response procedures - Technical tools and techniques - Communication protocols - Decision-making authority - Their specific role and responsibilities

Frequency: Annually at minimum, more often for new staff

1.14.2 12.2 Drills & Simulations

Tabletop Exercise: - Simulate incident scenario - Walk through response procedures - Identify gaps in procedures - Practice decision-making - Improve coordination

Frequency: Annually

Mock Incident: - Create realistic incident scenario - Full response activation - Real system access - Practice containment - Review performance

Frequency: Annually or after major changes

Example Drill Scenario:

SCENARIO: Data Breach Simulation

Date: [Test date]

Type: Unauthorized database access

Method: SQL injection attack

Data exposed: 500 user records

Attack method: External attacker

Detection: Automated monitoring alert

Response Team Actions:

1. Detect and assess

2. Activate response
3. Contain incident
4. Notify stakeholders
5. Investigate
6. Fix vulnerability
7. Recover
8. Post-incident review

Review:

- How well did we respond?
- What gaps exist?
- What training needed?
- What procedures need updating?

1.14.3 12.3 Knowledge Base

Maintain: - Incident response playbooks - Contact information (up-to-date) - System documentation - Known vulnerabilities - Remediation procedures - Tools and techniques - Historical incidents

Update: When procedures change, new vulnerabilities discovered, or after incident

1.15 Tools & Resources

1.15.1 13.1 Tools Required

For Incident Response: - Network monitoring tools (e.g., intrusion detection) - Log analysis tools - Forensic tools - Backup/recovery tools - Communication tools - Documentation tools

Current Toolset for QuizTimer4Zoom: - npm audit - Dependency scanning - ESLint - Code analysis - Git logs - Change tracking - Cloud monitoring - System observation - Application logs - Event documentation

1.15.2 13.2 Documentation Templates

Maintain ready templates for: - Incident report - Forensic report - Communication to users - Communication to Zoom - Notification to DPA - Post-incident review minutes - Action item tracking

1.15.3 13.3 Emergency Contacts

Keep Updated List: - Incident response team - Management/executives - Legal counsel - Data protection officer - Zoom security contacts - Law enforcement - DPA (Data Protection Authority) - Backup contacts

Location: Secure, accessible location (printed + digital backup)

1.16 Appendices

1.16.1 A. Incident Severity Examples

Critical Incidents: - “Our entire system is down and users can’t login” - “We detected unauthorized access to authentication system” - “500+ user records have been stolen” - “Attacker has deployed ransomware on our servers” - “Customer payment data has been exposed”

High Incidents: - “Failed login attempts from multiple IPs detected” - “Vulnerability found that could allow remote code execution” - “50 user email addresses may have been exposed” - “System performance severely degraded for 1 hour” - “Unauthorized modification of 10 user records”

Medium Incidents: - “Configuration error allows temporary data exposure” - “Vulnerability in non-critical system found” - “Password reset required for 5 accounts” - “Suspicious activity detected and blocked” - “Single user account compromise”

Low Incidents: - “Old protocol still enabled in production” - “Deprecated security method found” - “Non-sensitive data logging” - “Firewall rule alert (false positive)”

1.16.2 B. Response Time Targets

Incident Phase	Target Time	Critical	High	Medium	Low
Detection → Report	Immediate	15 min	30 min	1 hour	1 day
Report → Assessment	15 min	15 min	15 min	30 min	1 day
Assessment → Containment	30 min	30 min	1 hour	4 hours	1 day
Containment → Investigation	Ongoing	1 hour	4 hours	1 day	3 days
Investigation → Remediation	Ongoing	4 hours	1 day	3 days	1 week
Notification → User	72 hours	24 hours	72 hours	30 days	None

1.16.3 C. Incident Checklist

For Incident Commanders:

INCIDENT ACTIVATION CHECKLIST

- [] Confirm incident is real
- [] Assign incident ID (INC-YYYY-SEQUENCE)
- [] Assess severity level
- [] Activate response team
- [] Establish communication channel
- [] Brief team on situation

- [] Assign roles
- [] Document timeline
- [] Preserve evidence
- [] Check for ongoing attack
- [] Brief management
- [] Decide on containment strategy
- [] Execute containment
- [] Monitor containment
- [] Brief stakeholders
- [] Prepare notifications (if needed)
- [] Send notifications
- [] Begin investigation
- [] Continue response phases
- [] Schedule post-incident review
- [] Close incident

1.16.4 D. Communication Templates

Internal Incident Alert:

INCIDENT ALERT - INC-YYYY-001

SEVERITY: [CRITICAL/HIGH/MEDIUM/LOW]

TIME: [Time in UTC]

SYSTEM: [Affected system]

STATUS: [ACTIVE/CONTAINED/RESOLVED]

SITUATION:

[Brief description]

IMPACT:

[What's affected]

ACTION:

[What we're doing]

CONTACT:

[Incident Commander name/number]

User Notification (Data Breach):

Subject: Important Security Notice Regarding Your Account

Dear User,

We are notifying you of a security incident that occurred on [date]. An unauthorized party gained access to [description of what data].

Your [specific data] may have been accessed.

We have immediately:

- Contained the incident
- Fixed the vulnerability
- Enhanced monitoring
- Secured your account

What you should do:

- Review your account
- Change your password
- Enable multi-factor authentication
- Contact us if you see suspicious activity

We apologize for this incident.

Contact: info@fuzzy.monster

1.17 Policy Review & Updates

1.17.1 E.1 Review Schedule

- **Next Review:** 2026-10-28
- **Review Frequency:** Annually
- **Emergency Review:** After each incident

1.17.2 E.2 Updates

This policy will be updated when: - Procedures change - New incident types identified - Lessons learned from incidents - Regulatory changes - Technology changes - Feedback from drills

1.18 Document Information

Document: Incident Response Policy **Company:** Fuzzy Monster **Application:** QuizTimer4Zoom **Domain:** fuzzy.monster **Version:** 1.0 **Effective Date:** 2025-10-28
Last Updated: 2025-10-28 **Next Review:** 2026-10-28 **Classification:** Internal - Sensitive

1.19 Approval & Sign-Off

Prepared By: Latz **Email:** info@fuzzy.monster

Policy Status: Active and Approved

For questions regarding this Incident Response Policy:

Primary Contact: security@fuzzy.monster **General Contact:** info@fuzzy.monster
Website: https://fuzzy.monster

This policy is classified as Internal - Sensitive and should not be shared outside the organization without authorization. Regular drills and training are required to maintain effectiveness.